Sécurité des systèmes informatiques

Gouvernance, stratégie et politique de sécurité

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

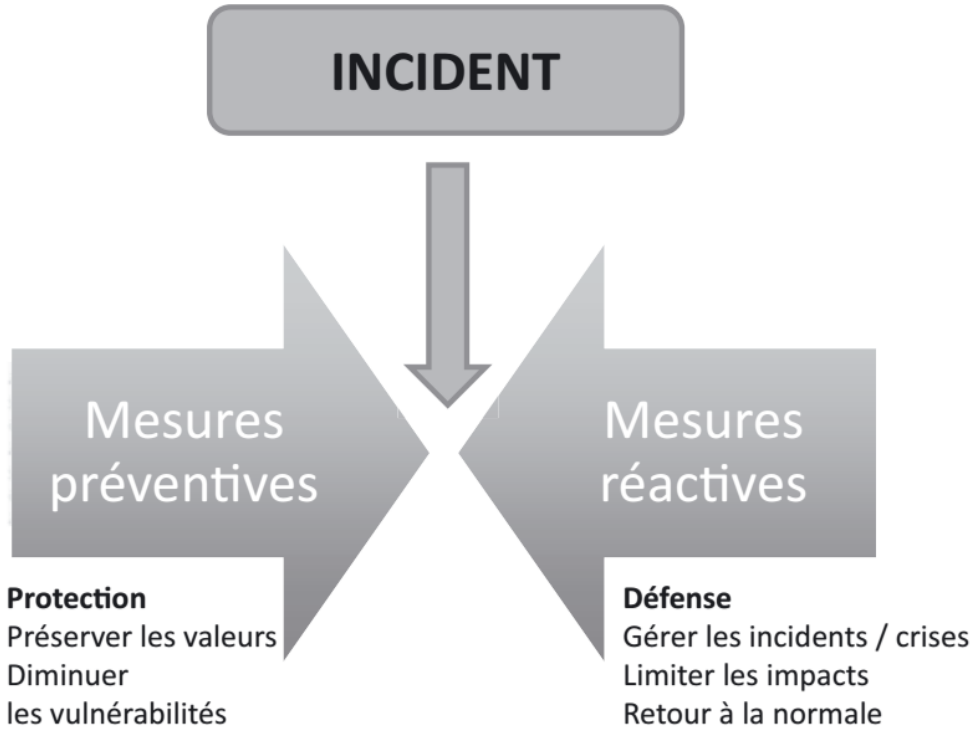
Contenu

- Stratégie de sécurité
- Analyse du risque
- Politique de sécurité
- Mesures de sécurité

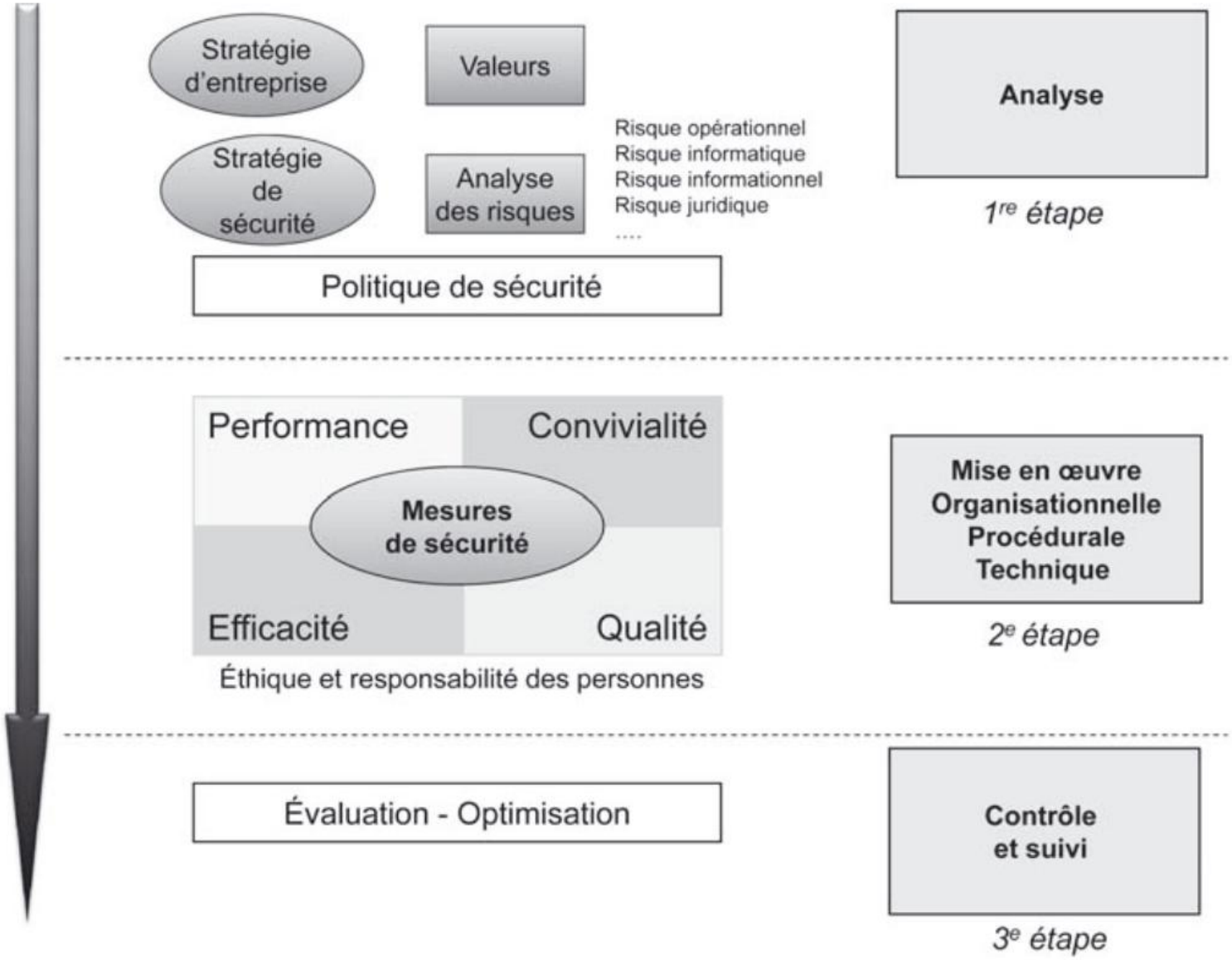
Stratégie de sécurité

- Consiste à concevoir une conduite générale de
  - Protection
  - Prévention
  - Organisation de la défense
  - Élaboration de plans de réaction
  - Gestion de crises
  - Gestion de la continuité et de la reprise des activités
  - Gestion des poursuites pénales (s'il y a lieu)

- S'inscrit dans démarche **proactive** et **réactive**
  - Anticiper et être préparé à prévenir et à gérer les incidents de sécurité



Étapes de réalisation d'une démarche sécuritaire



Vision stratégique de la sécurité

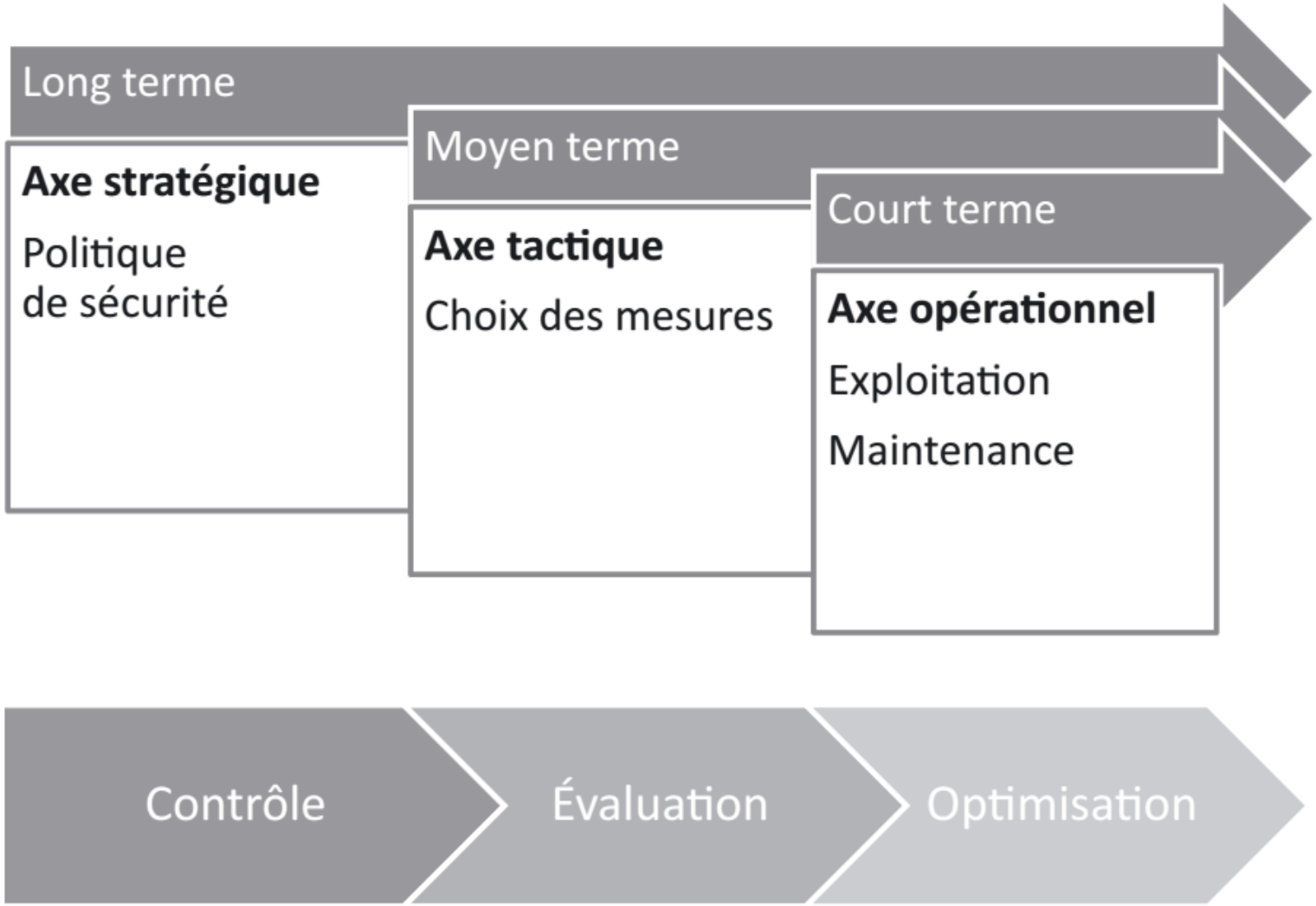
Propriété	Description
Disponibilité	Aucun retard
Intégrité et exactitude	Aucune falsification Aucune erreur
Confidentialité	Aucune écoute illicite
Pérennité	Aucune destruction
Non-répudiation et imputabilité	Aucune contestation
Authentification	Aucun doute sur l'identité d'une ressource, sur l'origine ou la destination d'une transaction
Intimité numérique (*privacy*)	Aucune mise à défaut de la protection de la sphère privée de l'utilisateur Protection des données personnelles
Respect des contraintes légales ou règlementaires	Aucun risque juridique

➔ **Réalisés** avec: des **outils technologiques** (antivirus, pare-feu, etc.), **procédures** (gestion des identifications et du contrôle d'accès, etc.) et de **personnes** (recrutement, sensibilisation, formation, etc.)

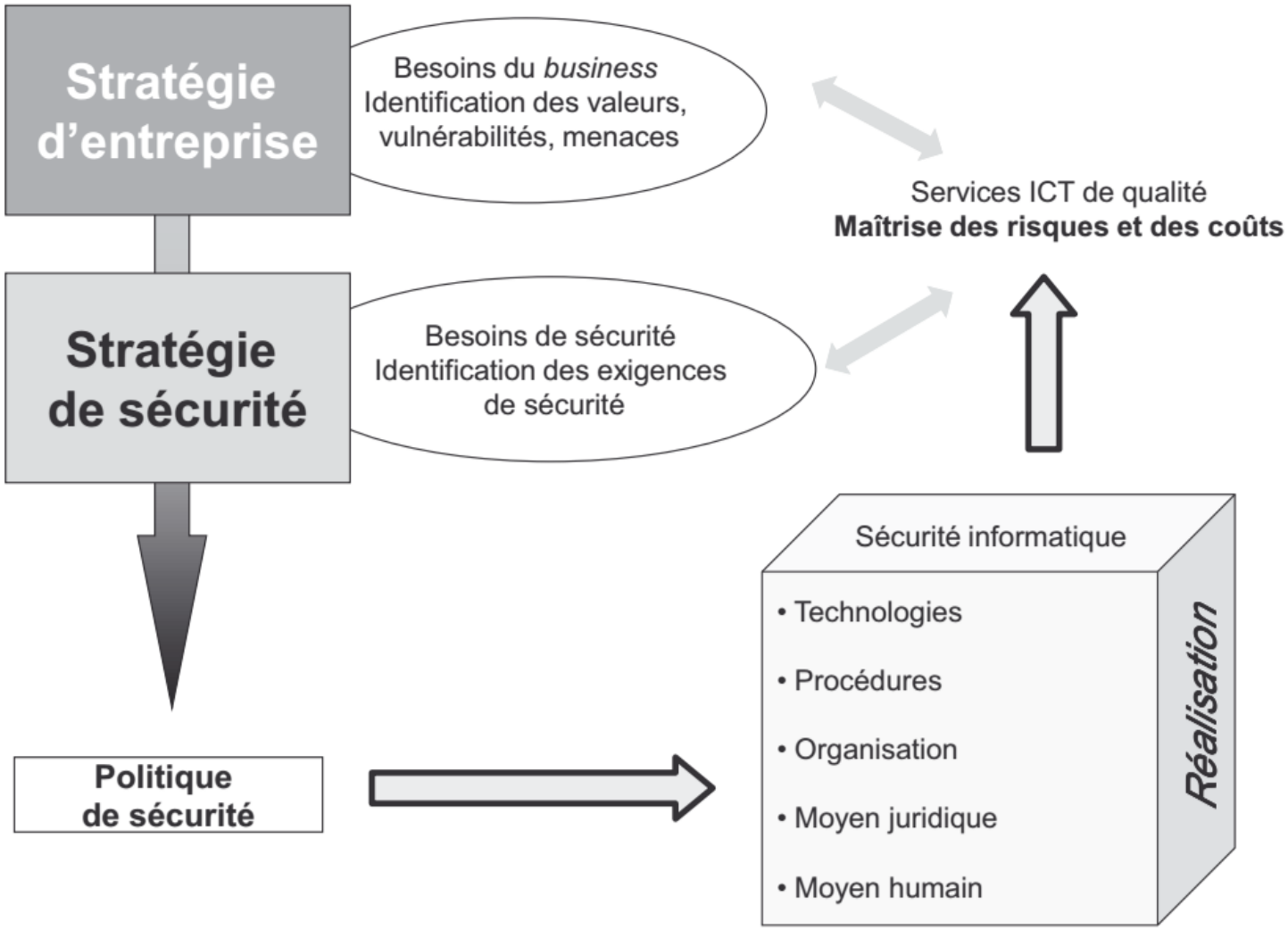
Principes de base

Principe	Description
Principe de vocabulaire	Langage commun de définition de la sécurité
Principe de volonté directoriale	La considération de l'information comme ressource stratégique Les dirigeants doivent libérer les moyens nécessaires à la mise en œuvre et à la gestion de la sécurité informatique
Principe financier	Le coût de la sécurité doit être en rapport avec les risques encourus
Principe de cohérence	Une accumulation d'outils sécuritaires n'est pas suffisante pour réaliser un niveau global, cohérent, et satisfaisant de sécurité
Principe de simplicité et d'universalité	Les mesures de sécurité doivent être simples, compréhensibles pour les utilisateurs et doivent s'appliquer à l'ensemble du personnel
Principe de dynamicité	La sécurité doit être dynamique pour intégrer la dimension temporelle de la vie des systèmes et l'évolution des besoins et des risques
Principe de continuum	L'organisation doit continuer à fonctionner même après la survenue de sinistre
Principe d'évaluation, de contrôle et d'adaptation	Il est impératif de pouvoir évaluer régulièrement l'adéquation des mesures de sécurité au regard des besoins effectifs et évolutif de la sécurité

Axes stratégique, tactique et opérationnel de la sécurité



Contexte d'une stratégie de sécuritaire

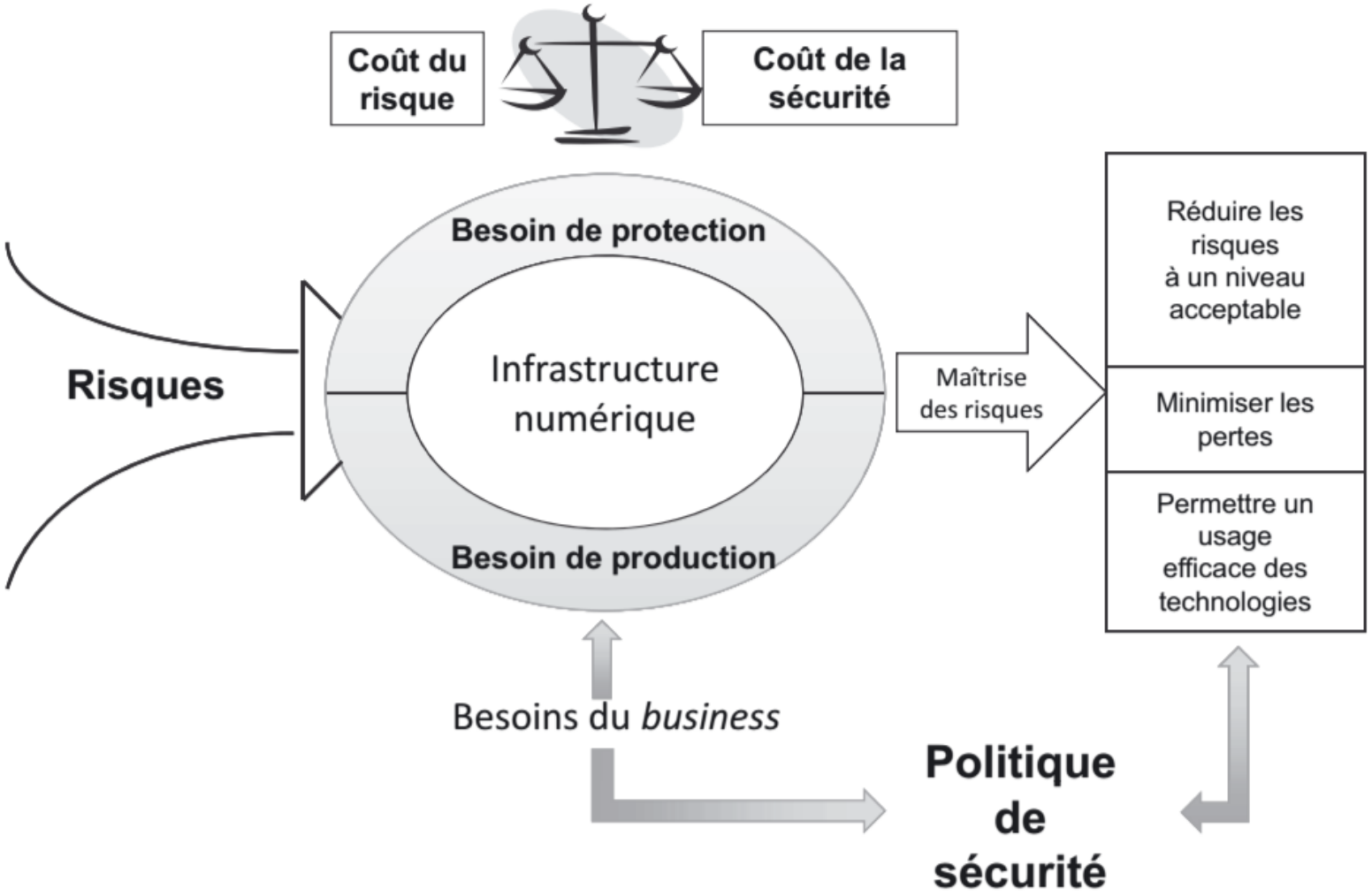


Stratégie de sécurité: questions à poser?

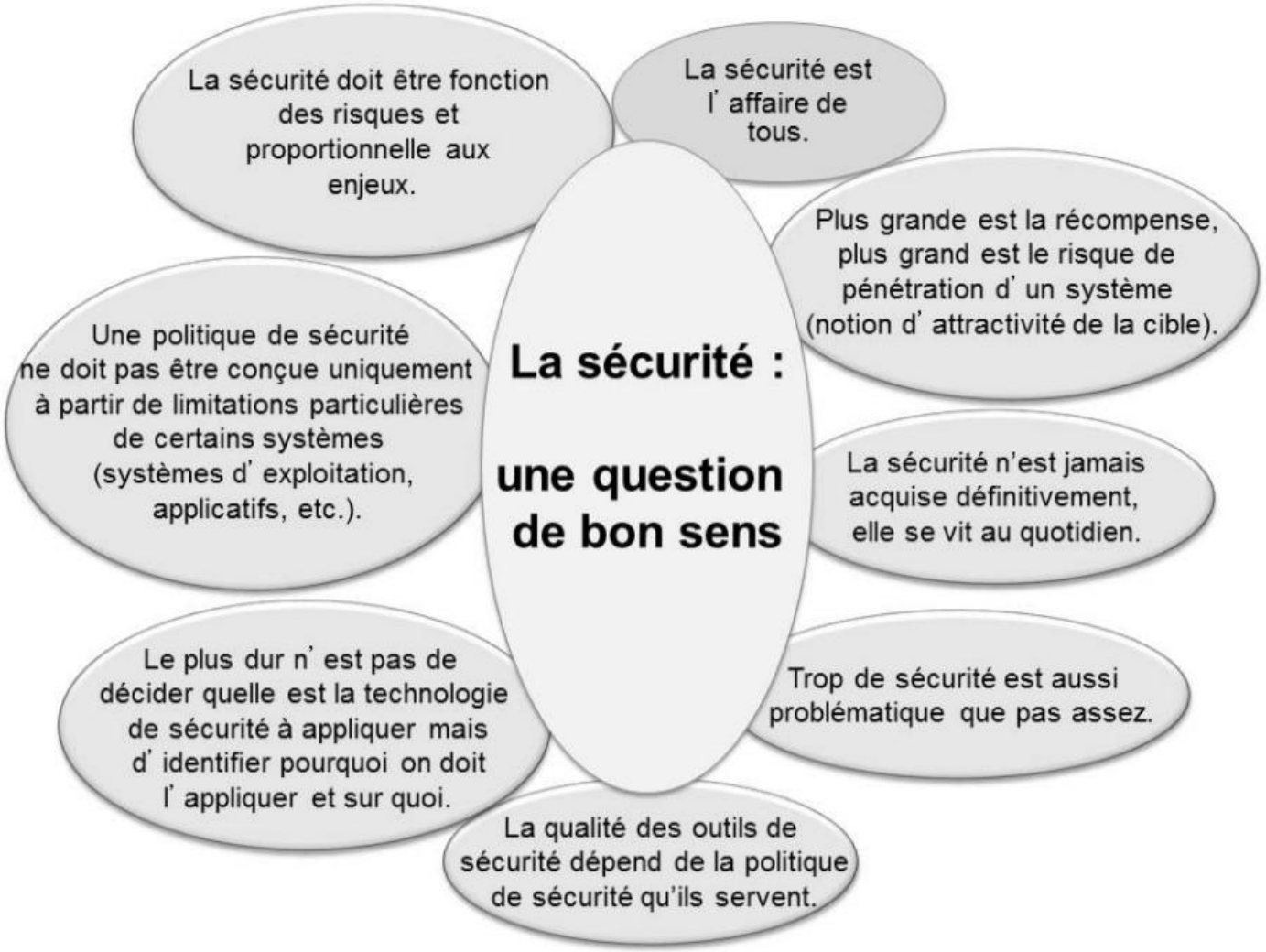
- Nécessité: bon sens, vision, analyse, compromis et choix
- Quelles sont les valeurs (actifs) de l'organisation?
- Quel est leur niveau de sensibilité ou de criticité?
- De qui, de quoi doit-on se protéger?
- Quels sont les risques réellement encourus?
- Ces risques sont-ils supportables?
- Quel est le niveau actuel de sécurité?
- Quel est le niveau de sécurité que l'on désire atteindre?
- Comment passer du niveau actuel au niveau désiré?
- Quelles sont les contraintes effectives?
- Quels sont les moyens disponibles?

Compromis et bon sens

- La sécurité est une question de compromis … et de bon sens



Compromis et bon sens (suite)



Principe
Principe de vocabulaire
Principe de volonté directoriale
Principe financier
Principe de cohérence
Principe de simplicité et d'universalité
Principe de dynamicité
Principe de continuum
Principe d'évaluation, de contrôle et d'adaptation

Acteurs et responsabilités

Acteur	Responsabilités
Responsable de sécurité (CISO : *Chief Information Security Officer*)	• Contrôler la gestion et l'administration des moyens et des mesures de sécurité • Définir les privilèges d'accès aux ressources et les réévaluer régulièrement • Élaborer et maintenir la documentation utilisateur et administrateur • S'assurer que les cibles de sécurité sont sous surveillance
Responsable des ressources humaines	• Effectuer les contrôles nécessaires avant l'engagement des nouveaux collaborateurs • Sensibiliser les nouveaux collaborateurs à leurs responsabilités en termes de sécurité • Coordonner les activités lors d'une rupture de contrat d'un collaborateur
Chefs de service	• Veiller à ce que leurs collaborateurs soient informés de la politique de sécurité • Informer les administrateurs de la sécurité de toutes les modifications ayant un impact potentiel sur le niveau de sécurité ou sa gestion • Analyser, valider et prendre position par rapport aux demandes d'accès aux ressources • Recenser et récupérer les informations sensibles détenues par un collaborateur qui quitte l'organisation
Utilisateurs	• Respecter les règles et les pratiques définies par la politique de sécurité • Informer le responsable de sécurité de tout élément ayant un impact sur la sécurité

Le risque

- Un risque est un danger éventuel plus ou moins prévisible
- Il se mesure à la probabilité qu'il se produise et aux impacts et dommages consécutifs à sa réalisation
- C'est la prise en compte de l'exposition à un danger, un préjudice ou tout autre évènement dommageable
- Un risque exprime la probabilité qu'une valeur soit perdue en fonction d'une **vulnérabilité** liée à une **menace**, à un danger ou événement non sollicité
- Traitement du risque
  - Réduction
  - Acceptation
  - Transfert
  - Arrêt de l'activité

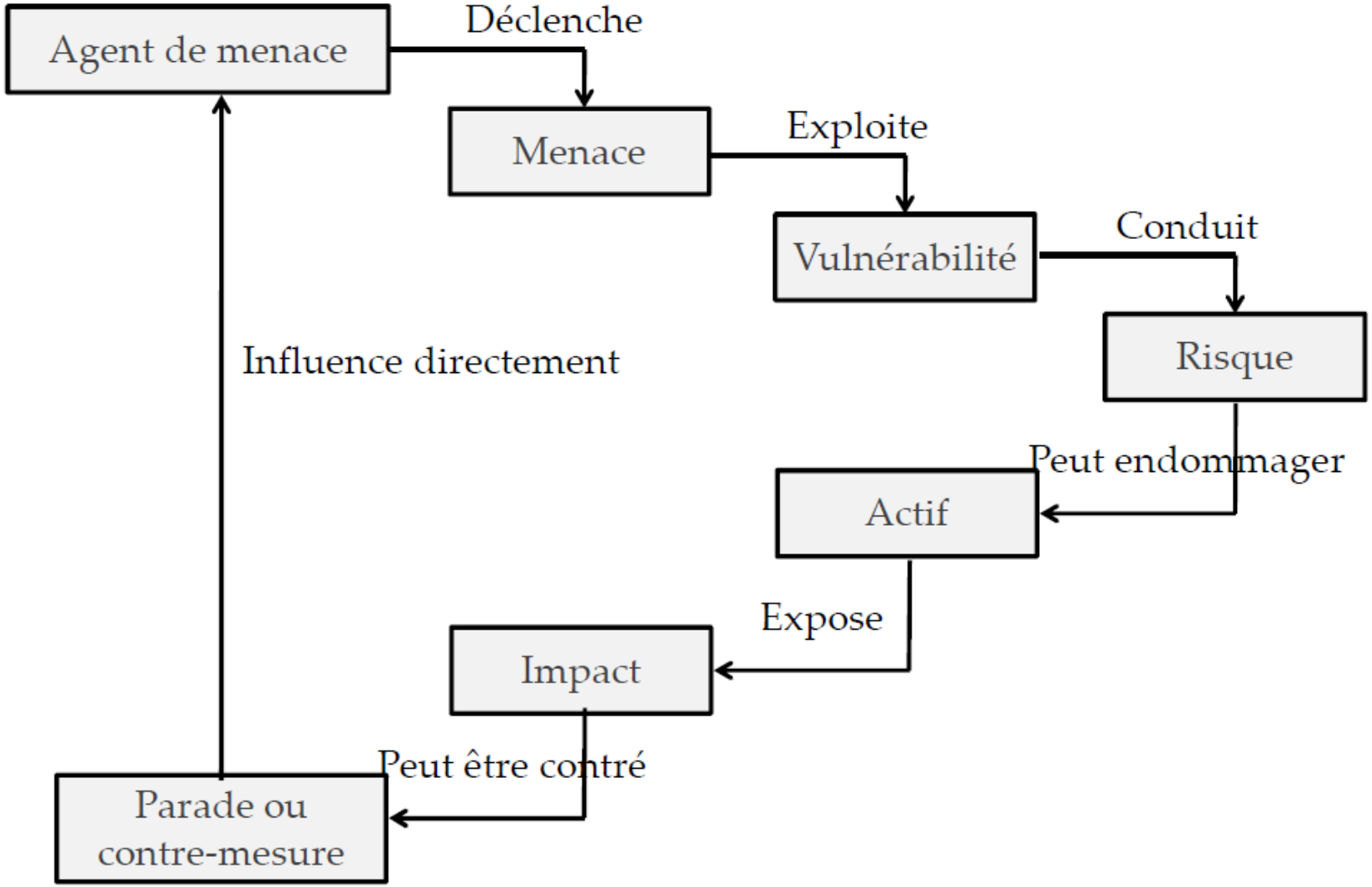
Terminologie du risque

Terme	définition	exemple
Actif	Objet ayant de la valeur (y compris l'humain)	Serveur de production
Menace	Entité physique ou morale qui met un actif à risque	Virus
Vulnérabilité	Faille qui donne l'opportunité de porter atteinte à un actif et donc de concrétiser une menace	Absence d'antivirus sur le serveur
Impact	Perte ou dommage causé à un actif	Perte de la base de données
Scénario	Exploitation d'une vulnérabilité par une menace pour causer un impact	Le virus est introduit dans le serveur pour détruire le contenu de la base de données
Contre-mesure (parade)	Protection d'un actif contre une menace	Antivirus

Terminologie du risque (suite)

- La menace peut être
  - Interne ou externe
  - Acte accidentel (erreur) ou délibéré
- Origines de la menace
  - Catastrophes naturelles
  - Pirates (*hackers*)
  - Compétiteurs
  - États étrangers
  - Crime organisé
  - Terrorisme
  - **Ceux à qui on fait confiance …**

Terminologie du risque (suite)



Analyse du risque

Risque = *f*(vulnérabilité, menace, impact)

- Difficulté d'évaluer le risque avec précision
- Plusieurs méthodologies
  - ISACA
    - *Risk IT Framework*
  - EBIOS
    - Expression des besoins et identification des objectifs de sécurité
  - MEHARI
    - *Méthode harmonisée d'analyse des risques*
  - OCTAVE
    - *Operationally Critical Threat, Asset and Vulnerability Evaluation*
  - Etc.

Analyse du risque (suite)

- Formule: **R(Risque) = P(Probabilité) x I(Impact)**
- Évaluation de l'impact
- Faire le recensement et la classification des actifs informationnels
  - S'appuyer sur les propriétaires des actifs
  - Exemples
    - Le directeur informatique est le propriétaire du système VPN, des composantes pare-feu
    - Le directeur de la paie est le propriétaire du système informatique qui gère la paie
- Quantifier l'impact en fonction
  - de la classification de l'impact
  - de l'échelle choisie
  - des processus et objectifs d'affaires

R(Risque) = P(Probabilité) x I(Impact)

Analyse du risque (suite)

- Évaluation de l'Impact (suite)
- Définir une échelle d'appréciation de l'impact (Exemple: échelle semi-objective)

Valeur	Impact
1	**Faible**: perte d'argent ou de données négligeable, courte indisponibilité, effet minime sur la réputation, etc.
2	**Moyen**: perte d'argent significative, perte de données peu dommageable, indisponibilité de plusieurs heures, etc.
3	**Élevé**: importante perte d'argent, perte d'un grand volume de données, indisponibilité de plusieurs jours, etc.
4	**Très élevé**: perte de plusieurs centaines de milliers (millions) de dollars, divulgation de secrets d'affaires, indisponibilité indéfinie, etc.

- Exemples
  - Le vol d'une base de données de clients pourrait coûter la réputation à une compagnie
  - L'incendie d'une salle de serveurs de petite taille (une dizaine de serveurs) pourrait coûter plus de $100.000 à la compagnie

R(Risque) = P(Probabilité) x I(Impact)

Analyse du risque (suite)

- Évaluation de la Probabilité
- Il est question de déterminer la probabilité d'observer un impact dans un scénario de risque donné
  - Pour les risques accidentels
    - Utilisation d'une échelle **exacte**: données actuarielles
  - Pour les risques délibérés
    - Utilisation d'une échelle **semi-objective**

Valeur	Probabilité
1	**Faible**: probabilité presque nulle
2	**Moyen**: peu probable
3	**Élevé**: probable
4	**Très élevé**: très probable

R(Risque) = P(Probabilité) x I(Impact)

Analyse du risque (suite)

- Évaluation de la Probabilité (suite)
- Dépend de l'intervenant (attaquant)
  - Experts en sécurité, experts en systèmes, propriétaire du système, etc.
- Trois grandes composantes de la probabilité

Composante	Description
Capacité	• Savoir et connaissances • Outils et argent • Accès au savoir et aux ressources humaines
Opportunité	• Espace: avoir un accès physique • Connectivité: existence d'un lien physique et logique • Temps: être « là » au bon moment
Motivation	• Qui: à qui profite le crime? • Quoi: que va gagner le malfaiteur? • Combien: Combien va gagner le malfaiteur?

R(Risque) = P(Probabilité) x I(Impact)

Analyse du risque (suite)

- Évaluation de la Probabilité (suite)
- Combinaison des composantes (Capacité, Opportunité, Motivation)
  - Produit des trois composantes?
  - Médiane des trois composantes?
  - Minimum ou maximum des trois composantes?
  - Moyenne des trois composantes?

R(Risque) = P(Probabilité) x I(Impact)

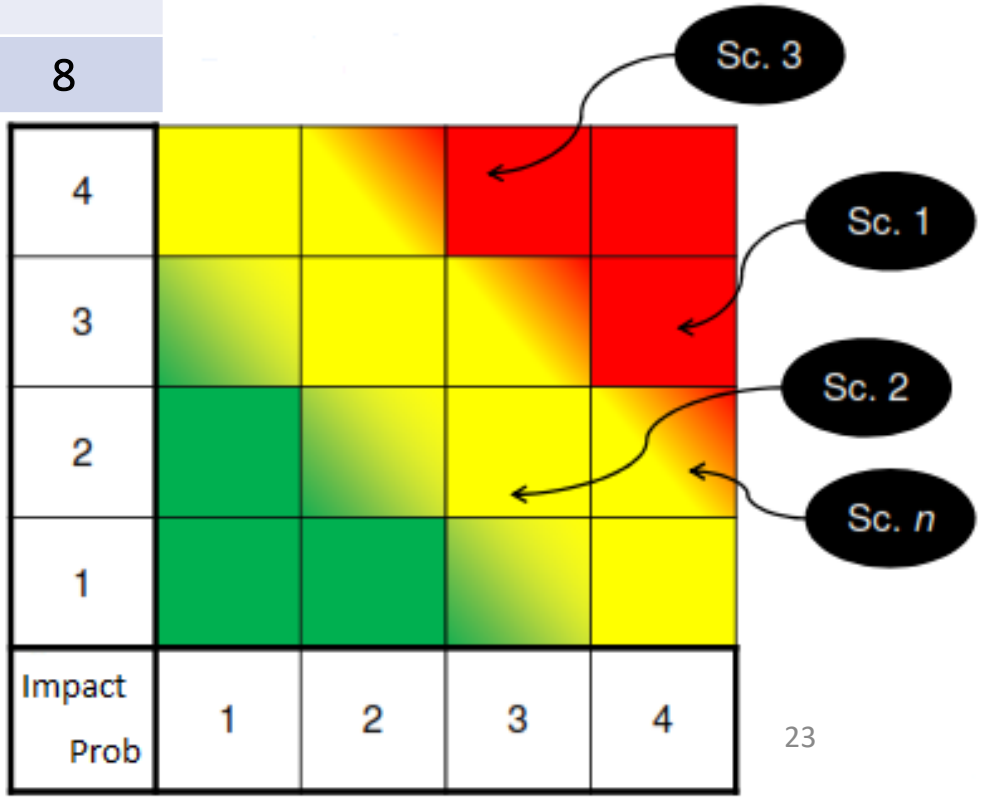
Analyse du risque (suite)

- Tableau d'analyse du risque

Scénario	Capacité	Opportunité	Motivation	Probabilité	Impact	Risque
1	1	4	3	4	3	12
2	3	2	1	3	2	6
3	2	2	3	3	4	12
…						
n	3	1	4	4	2	8

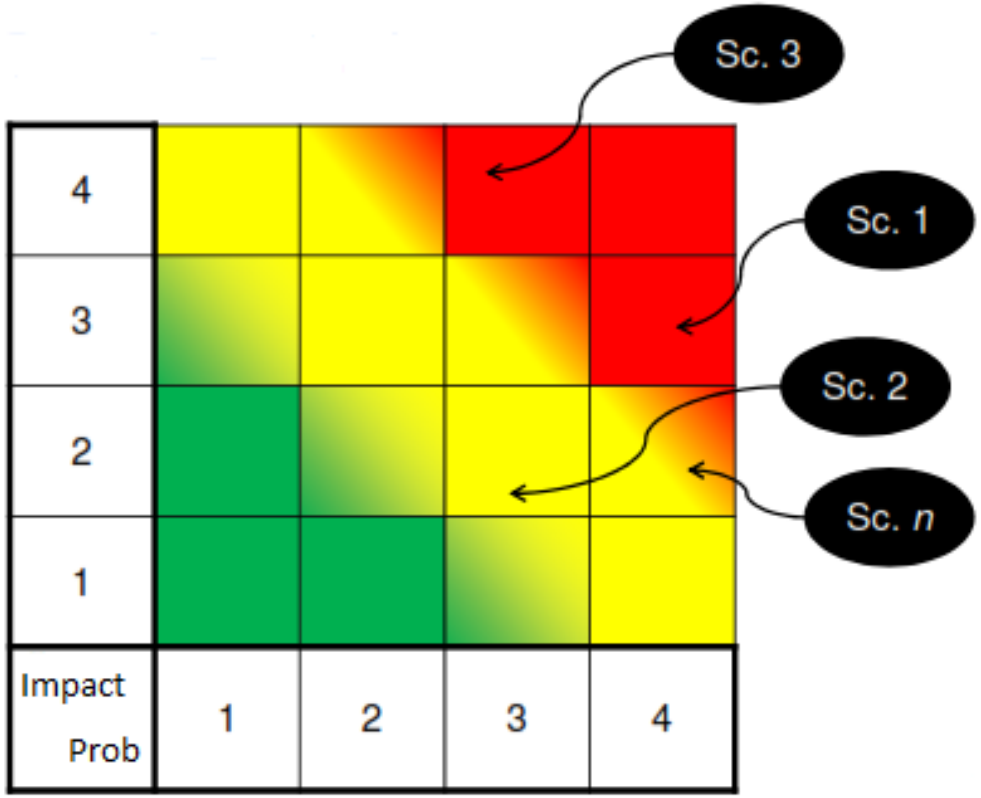
- Dans cet exemple, la probabilité est le **maximum** des trois composantes: Capacité, Opportunité et Motivation

Échelle LOG



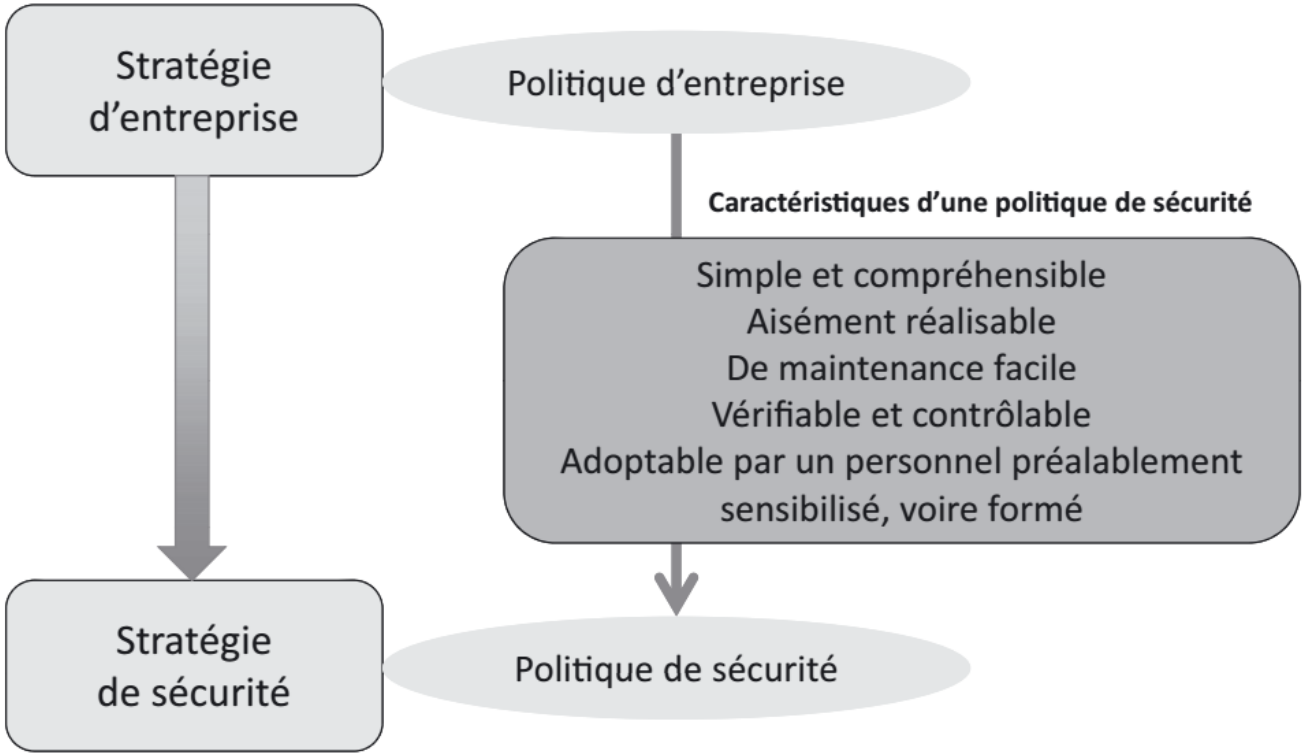
Analyse du risque (suite)

- Tableau d'analyse du risque
- Interprétation de l'échelle LOG
  - Prioritairement, on doit s'occuper de la zone rouge (scénarios 1 et 3)
  - Selon le niveau de tolérance au risque, on peut aussi s'occuper de la zone jaune
    - Scénarios n et 2
    - Si on est très tolérant, on accepte tout ce qui se trouve dans la zone jaune
    - Si on est peu tolérant, on contrôle même ce qui se trouve dans la zone jaune
  - Le contrôle se fait à travers la mise en place de parades (contre-mesures)



Politique de sécurité

- Permet l'expression et la concrétisation d'une stratégie de sécurité
- Exprime la volonté managériale de protéger les valeurs informationnelles et les ressources technologiques de l'organisation
- Spécifie les moyens (ressources, procédures, outils …) qui répondent de façon **complète** et **cohérente** aux objectifs stratégiques de sécurité



Contexte d'une politique de sécurité (suite)

Politique de sécurité (suite)

- Réalisation de mesures, fonctions, procédures et de services

Exemples
Règles de **classification de l'information** et d'**utilisation des ressources**
Outils: **contrôle d'accès**, **chiffrement** des données, **authentification**, systèmes de **pare-feu** ou de **détection d'incidents**, de surveillance et d'enregistrement, **journalisation** et de traçabilité
Des contrats de service: clauses de responsabilité, devoirs et obligations
Des plans de gestion de crise, de secours, de **continuité** et de **reprise**
Des plans d'action de **poursuite en justice**

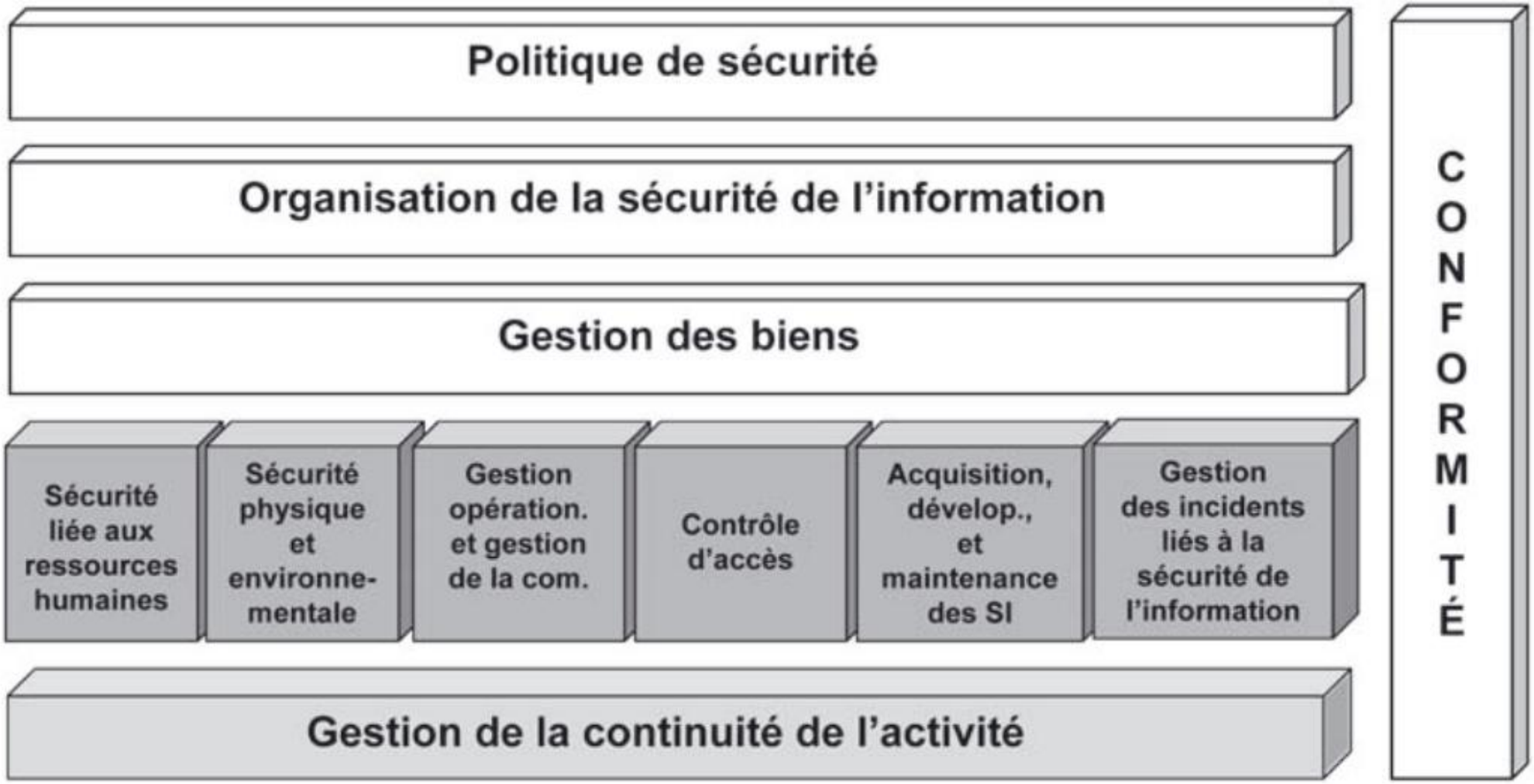
Composantes et propriétés d'une politique de sécurité

- La définition de la politique de sécurité doit être:
  - Simple et compréhensible
  - Aisément réalisable
  - De maintenance facile
  - Vérifiable et contrôlable
  - Adoptable par un personnel sensibilisé et formé

Normes ISO/IEC 27000

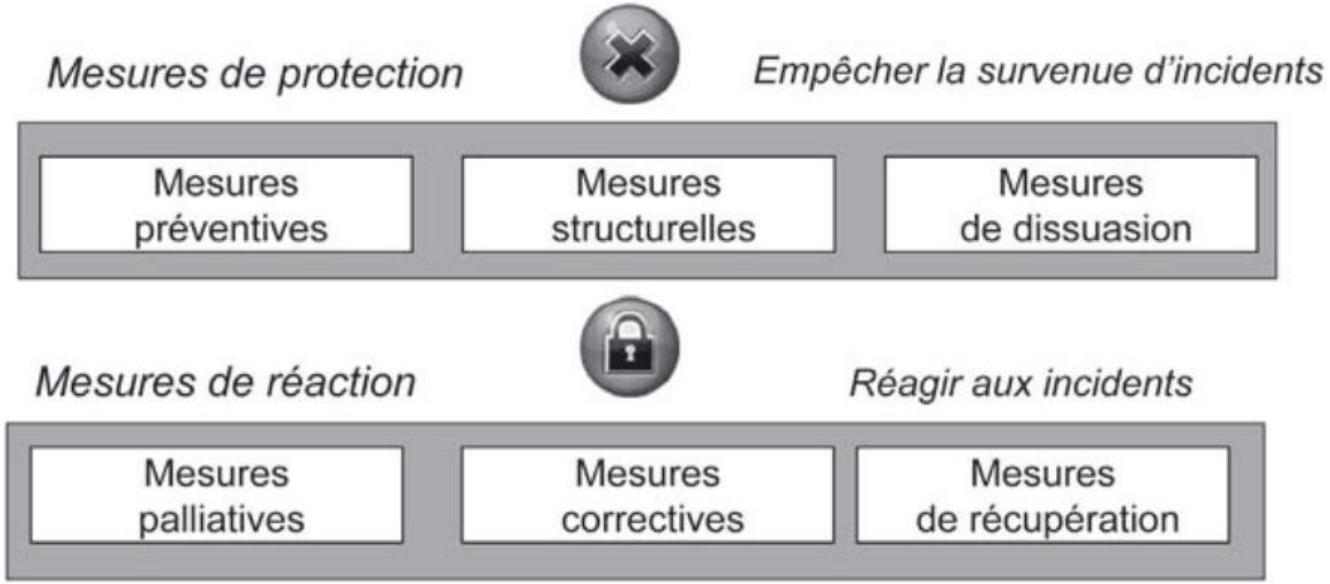
Norme	Description
ISO 27000	Notions fondamentales, vue d'ensemble et formalisation du vocabulaire.
ISO 27001	Exigences de sécurité d'un système de management de la sécurité.
ISO 27002	Code de bonnes pratiques pour la gestion de la sécurité de l'information.
ISO 27003	Lignes directrices pour la mise en œuvre et l'implémentation du Système de Management de la Sécurité de l'Information (SMSI).
ISO 27004	Métriques du management de la sécurité de l'information.
ISO 27005	Gestion du risque en matière de sécurité de l'information.
ISO 27006	Exigences pour les organismes auditant et certifiant un SMSI.
ISO 27007	Directives concernant le processus d'audit d'un SMSI.
ISO 27008	Directives pour les auditeurs concernant les contrôles à effectuer dans un SMSI.
ISO 27011	Management de la sécurité de l'information pour les organismes de télécom.
ISO 27031/33	Plan de continuité des affaires et principes généraux de la sécurité des réseaux.
ISO 27799	Gestion de la sécurité de l'information relative à la santé.

Exemple: chapitres de la norme ISO 27002

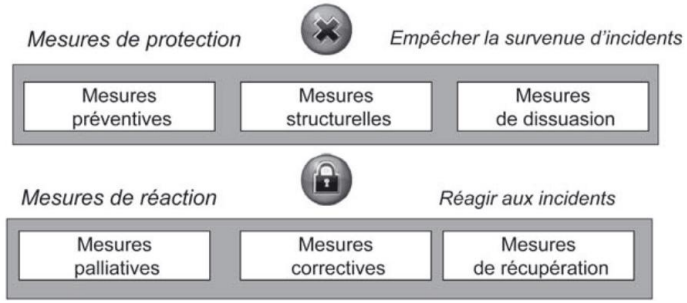


Mesures de sécurité

- De la politique aux mesures de sécurité …
- Il s'agit:
  - **De mesures procédurales et managériales**
    - Procédures de gestion, de surveillance, d'évaluation, de mises à jour, de sauvegarde, de gestion des ressources humaines, etc.
  - **D'outils technologiques matériels ou logiciels**
    - Protocoles cryptographiques, pare-feu, système de filtrage, de contrôle d'accès, etc.
  - **De personnes**

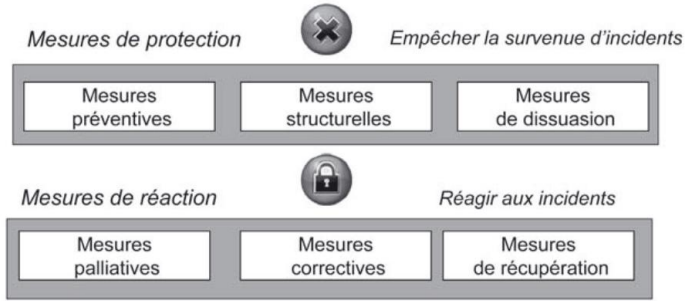


Mesures de sécurité (suite)



- **Mesures préventives**
  - Barrières afin d'empêcher la réalisation d'incidents, d'une malveillance ou d'une erreur
  - Procédures de contrôle d'accès physique, détecteurs de virus …
- **Mesures structurelles**
  - Agissent sur la structure, l'architecture, l'organisation du système d'information
  - Cloisonnement d'environnements, redondances, fragmentation de l'information, etc.
- **Mesures de dissuasion**
  - Décourager les agresseurs de mettre à exécution une menace
  - Procédures juridiques et administratives touchant à la sensibilisation et à la gestion des ressources humaines, moyens de détection et de traçage, etc.

Mesures de sécurité (suite)



- **Mesures de protection**
  - Renforcer la sécurité et la robustesse des ressources et diminuer les détériorations suite à la réalisation d'une menace
  - Contrôle de cohérence, détecteurs d'intrusions, d'incendies … pour se protéger des agressions ou d'en limiter l'ampleur
- **Mesures palliatives ou correctives**
  - Pallier ou réparer les dégâts engendrés par un incident et continuer les activités
  - Sauvegardes, plans de continuité, redondances, réparations ou corrections …
- **Mesures de récupération**
  - Retour à un fonctionnement normal, limiter les pertes consécutives à un sinistre, réduire le préjudice subi en transférant les pertes à de tierces parties (assurances)